

網路勒索病毒的特徵分析及探討

資工四 S10859050 郭宇倫

資工四 S10859045 呂建篁

資工四 S10859048 陳睦善

摘要

由於網路和無線感測技術的普及化以及物聯網和雲端服務的整合，常見的物聯網設備使用簡化的作業系統且無法安裝掃毒引擎，並且管理者缺乏持續系統更新，這容易引起資安疑慮，因為這些設備存在的漏洞可能遭受駭客攻擊，進而導致企業或個人的隱私資訊外洩或損失。因此本組將針對近年來出現的勒索病毒威脅並透過沙盒分析攻擊特徵(attack vectors)進行探討。

1. 介紹

勒索病毒是一種惡意程式，專門將本機與網路儲存的重要檔案加密後要求支付贖金才能解開檔案。駭客開發這類惡意程式目的是為了經由數位勒索來牟利。勒索病毒一旦被執行，就會搜尋本機與網路上的儲存裝置，尋找可加密的檔案。它會攻擊認為對您企業或個人重要的檔案，也包括可讓您復原資料的備份檔案。以著名的 WannaCry 勒索病毒為例，WannaCry 被認為利用美國國家安全局的「永恆之藍」工具以攻擊 Microsoft Windows 作業系統的電腦，被針對的副檔名共有 176 種，包括 Microsoft Office、資料庫、壓縮檔、多媒體檔案和各種程式語言常用的副檔名。「永恆之藍」利用了某些版本的微軟伺服器訊息區塊（Windows Server Message Block, SMB）協定中的漏洞，而當中最嚴重的漏洞是允許遠端電腦執行惡意程式碼，接著再將真正的勒索病毒檔案送入受害系統，它會用 .WNCRY 副檔名來對相關檔案進行加密。趨勢科技於 2017 年 4 月中首次監測到勒索病毒，最初是透過網路釣魚攻擊誘使使用者從 Dropbox 下載惡意程式，後來，趨勢科技發現這一個勒索病毒「WannaCry/Wcry」已進化為結合 SMB 伺服器漏洞 EternalBlue 與新勒索病毒家族的變種。由於網路勒索病毒 WannaCry 肆虐，台電也受害，全公司有 779 台電腦中毒，受害單位遍及台電上下，包括總管理處、水火電力廠及業務單位等，中毒電腦皆出現網路斷線並隔離搶修。

2. 文獻探討

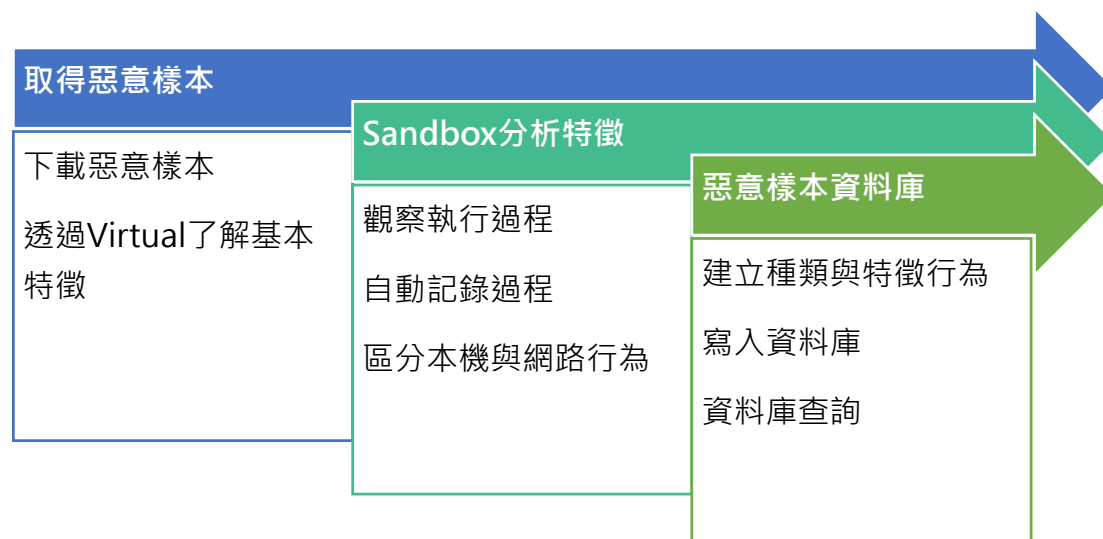
知名的 WannaCry 是其一勒索病毒，部分勒索病毒會透過 email 夾帶偽裝檔案使受害者執行後便寫入機碼內，開始進行加密行為，加密成功後便出現提示，使受害者發現系統內檔案已被加密，並要求受害者付款解鎖，各病毒間差異處主要為，加密系統主要利用系統漏洞及不同傳遞的手法進行攻擊，目前大多針對 Windows 系統，少部分針對 Linux、Mac OS。

勒索病毒的概念可追溯於 1989 年，該病毒為 AIDS Trojan 會替代開機執行檔，一旦執行達 90 次以上，便會隱藏並加密 C 槽內所有文件的名稱，要求使用者聯繫 PC Cyborg 付款，將美金寄到巴拿馬的郵政信箱，這是較為古老的病毒勒索方式，而在現今網路發達的時代，勒索病毒的傳遞與贖金取得更加無影無蹤，新型勒索病毒可能透過殭屍網路進行傳遞，並要求受害者支付數位貨幣，常見勒索病毒如下表所示：

作業系統	病毒名稱	描述
MS-DOS	AIDS Trojan	宣稱受害者某一軟體已結束授權，並加密磁碟上的檔案，要求支付美元給 PC Cyborg 以解除鎖定
Win32	Gpcode.AG	針對所有可讀取目錄之特定格式檔案進行加密，並在被加密的檔案目錄下建立 readme.txt 提供付費解鎖途徑
Win32	Gpcode.AK	是 Gpcode.AG 變種，與前一代不同之處在於使用 1024 位元 RSA 加密演算法加密
Windows	WinLock	顯示情色圖片遮蔽使用者瀏覽當前視窗，並提示受害者需支付簡訊付費以接收解鎖密碼
Windows	CryptoLocker	以 email 傳送偽裝 pdf 格式之 .exe 檔，啟動後會以隨機名稱寫入我的文件，並於登陸檔內新增機碼與開機同步啟動並產生 2048 位元之 RSA 加密金鑰
Windows	Petya	感染 MBR，受感染系統下次啟動時便加密 NTFS 檔案系統檔案表，完全阻止系統啟動 Windows，直至支付贖金
Windows	WannaCry	是一種利用 NSA 的永恆之藍 (EternalBlue) 漏洞透過網路 Windows 電腦進行加密利用 AES-128 和 RSA 演算法惡意加密用戶檔案以勒索比特幣
Windows	Bad Rabbit	誘使受害者下載偽裝成 Adobe Flash 的更新程式，一旦安裝後，電腦內的檔案文件便會被加密

3. 病毒動態分析方法

分析電腦病毒行為特徵常運用沙盒(sandboxing)以「病毒動態行為特徵分析(behavior analysis)」，沙盒是一個抽象的概念，是指「在一個特定的環境中，根據所需的安全性限制程式的行為」，讓程式放在模擬真實環境的沙盒內執行，對病毒做動態的追蹤，觀察是否有異常行為，透過此方式可不影響真實的系統環境檢測出病毒。知名沙盒包括 CWSandbox、Cuckoo、INetSim、TRUMAN，病毒動態行為特徵分析法流程如下圖，分析方法特徵整理如下圖：



	電腦病毒動態分析特性
特色	- 惡意程式須可被執行 - 在控制的環境下(沙盒)以虛擬主機執行並監控觀察惡意程式之感染行為 - 常使用模式與核心模式以分析不同病毒行為特徵，說明如下： User space Sandbox 會在系統函式庫中插入程式碼，以得到運作時應用程式 API 控制權或是透過 Debugger 執行軟體的 samples，但 User space sandbox 會被 Malware 軟體偵測到，進而故意模擬正常的行為，以規避 Sandbox，此時管理者就需要 Kernel sandbox。 - Kernel sandbox 解決此問題方法是在 Kernel 內監控 System calls，減少 Sandbox 被 Malware 察覺的機會
優勢	- 察覺未知惡意程式感染行為樣態 - 錯誤回報(false positives)減少
限制	- 約 30%病毒具反偵測執行環境之虛擬主機能力 - 動態所需分析時間長

CWSandbox 沙盒是一個開發模擬虛擬網路環境，能自動化分析惡意程式環境，如 TW MAN (Taiwan Malware Analysis Net)可用於分析惡意程式，取得惡意行為特徵。透過即時分析設備內生成日誌並搭配惡意程式檢測演算法，來判斷是否有應用程式上的惡意行為存在。

MalCatcher 系統是一個新型動態分析(dynamic analysis) Android 惡意程式行為的方法，其主要是針對 Android 系統原始碼進行修改及重新編譯且運行於模擬器上並建立一獨立受控制的環境以便 APP 導入執行，並將網路封包監控軟體 snort 重新交叉編譯為 Android 系統可執行之版本，用以監控網路封包是否有洩漏使用者隱私資料。

動態分析讓程式在虛擬環境下執行並監控觀察其行為，由於程式必須持續執行，因此需耗費運算時間。另外沙盒可依目的不同分為多種技術，例如要進行檢查而停在某個程式呼叫執行點、防止潛在危險而中止程式、程式運行時監控及記錄程式活動。現今目前資安實驗室常使用廣泛 CWSandbox 沙箱，是針對 Windows 或 Server 為主，運作可分成兩部份：

1. 靜態分析，利用程式特定字串來進行文字探勘(text mining)分析，並將分析結果寫入記錄檔 logfile。
2. 若靜態分析沒有偵測到符合的特定字串，則進行動態行為分析，使程式獨立在虛擬環境沙盒下執行，並記錄異常行為特徵，最後輸出至檔案。

另外進行靜態分析時，會把原始碼所有狀態轉換成模型，同時把原始碼轉換成抽象語意，並會把程式執行的所有可能發生的因素都考慮進來，因此靜態分析是具保守且可靠的。以上的技術有一個共通點是不會直接執行應用程式，因此靜態分析較快速且簡單，反之缺點是當病毒以多形(polymorphism)或變形(metamorphism)的方式呈現時，靜態分析會失效，故防衛者發展出程式語意分析(semantic analyzed)來對抗變種病毒。若沒有外部情報或手動檢查，一般靜態分析函數會採取規避行為且無法了解未知惡意程式感染行為之樣態，對新型變種病毒將無法即時偵測。

4. 結論

本組針對病毒動態分析及透過病毒之行為特徵分析進行收集資料並探討，並說明常見之勒索病毒類型所造成危害及歷史事件。運用沙盒在虛擬環境下執行並監控觀察其是否有異常行為，並進行文字探勘、語意分析來檢測勒索病毒。在未來，若能導入深度神經網路(Deep Neural Networks, DNN)針對多種新型病毒、變異病毒的攻擊行為、特徵進行學習分析，以利於能即時判斷變異病毒或有效偵測潛藏的風險。

參考文獻

1. TechNews, “史上第一勒索蠕蟲 WannaCry / Wcry 大舉入侵，趨勢科技教你週一拒當資安人質”，2017 年 05 月 15 日
2. 陳驚人, “勒索病毒襲台 台電也中鏢”，中時電子報，2017 年 05 月 15 日，
<https://www.chinatimes.com/realtimenews/20170515003208-260405?chdtv>
(2018/7/29)
3. 林建宏、方國定, “正規化概念分析建構電腦病毒特徵之知識本體”，國立雲林科技大學資訊管理系碩士論文，2009。
4. Trend Labs 趨勢科技全球技術支援與研發中心, “勒索病毒 ransomware /勒索軟體”，2015 年 02 月 01 日
5. 戚玉樑, “以本體技術為基礎的知識庫建置程序及其應用”，資訊科技與社會，第五卷第二期”。2005，頁 1~18。
6. 王平、王宇治, “行動裝置病毒知識本體雛型之建構-以 Android 系統為例”，第 24 屆國際資訊管理學術研討會(ICIM2013)，真理大學，2013。
7. 黃盈豪, 許通安, “以知識本體為基礎建構病毒分類知識庫系統”，中原大學資訊管理研究所碩士論文，2007。
8. 亞俊、孫宏民, “核心層即時 Android 惡意軟體偵測之研究”，國立清華大學資訊系統與應用研究所碩士論文，2012。
9. 謝維揚、曾文貴, “MalCatcher: 以存取以及網路洩漏隱私資料行為為基礎的 Android 惡意程式行為偵測”，國立交通大學網路工程研究所碩士論文，2013。
10. 鄧全良、徐雄健, “以虛擬程式載入器及病毒行為模式分析法的防毒系統”，銘傳大學 資訊工程學系碩士論文，2004。
11. 張世杰、洪士灝, “Ape: Android 系統惡意程式之自動化測試環境”，國立臺灣大學資訊工程學研究所碩士論文，2013。
12. 吳迪、林大為, “惡意程式碼的檢測研究”，健行科技大學資訊工程所碩士論文，2013。
13. <https://applealmond.com/posts/5171>